Usage and Quota Limitations

LESSON 2.2.7

How AI gateways enforce usage and quota controls including input data size limits, quantity quotas, modality restrictions, and authentication to protect AI systems from abuse, resource exhaustion, and unauthorized access.

Input Quota — Data Size

Input quotas define the total volume of data a user or application can submit to the model over a given period, measured in megabytes, gigabytes, or total token count. Without these controls, high-bandwidth prompts can consume excessive processing power, memory, and network capacity.

Why It Matters in RAG Systems

Large document uploads in RAG pipelines create compounding risks: storage overload, degraded indexing performance, and slow query responses. File size limits at the gateway ensure only manageable inputs enter the system.

Security Threats

- Attackers upload excessively large files to cause resource exhaustion or denial of service for legitimate users
- Uncontrolled large file uploads may contain sensitive data that bypasses validation pipelines
- Enforcing size limits at the gateway is the first and most effective line of defense

Input Quota — Quantity

Quantity quotas control the total number of files, documents, or data items a user or application can upload or process within a defined time window. These limits apply at multiple levels to prevent any single actor from exhausting shared capacity.

1

Per Session

Max documents submitted in a single interaction, e.g., 20 documents per session preventing immediate bulk abuse.

2

Per Day

Daily caps such as 200 documents limit sustained high-volume activity from a single user or client application.

3

Per Month

Subscription-level caps (e.g., 1,000/month) align resource consumption with service tiers and billing agreements.

4

Per Application

Aggregate quotas across API integrations prevent a single client from monopolizing system capacity.

Attacker Vector: Adversaries may split malicious content across many small files to evade per-file detection. Clear per-user and per-session upload limits at the gateway directly mitigate this evasion technique.

Modality Limits

Modality limits define which types of input and output a model is permitted to handle — text, images, audio, video, file uploads, and more. Each modality unlocks new capabilities but also introduces distinct risk surfaces that must be centrally governed.

Healthcare Chatbot Example

May allow text input for clinical queries while explicitly blocking audio recordings and image uploads to reduce PHI exposure and compliance liability.

Content Generation Tool Example

May permit image uploads for creative workflows while blocking video to control processing costs and prevent large-file abuse vectors.

Gateway-Level Central Enforcement

Centralizing modality control at the gateway ensures consistent policy, faster reaction to emerging risks, simpler compliance auditing, and tighter cost management across all applications simultaneously.

Modality Security Risks

Each modality accepted by an AI system is a potential attack vector. Without explicit gateway-level restrictions, models become exposed to a wide range of injection attacks, illegal content, unintended actions, and intellectual property violations.

Malicious Files

PDFs and documents may contain embedded scripts, macros, or payloads designed to exploit parsing vulnerabilities in the model or its toolchain.

Prompt Injection via Media

Hidden instructions can be embedded in audio transcriptions or image metadata, invisibly directing the AI to perform unauthorized actions.

High-Risk Plugin Actions

Application-like features and plugins may inadvertently allow sending emails, fetching unsafe URLs, or accessing connected systems creating serious operational risk.

Copyright Infringement

Uncontrolled media inputs — images, audio, and video may contain protected intellectual property, creating legal exposure for the organization.

Authentication and Authorization Controls

AI gateway authentication verifies user and application identity before granting access to LLM endpoints. Rather than relying on a single master API key which exposes the entire system if compromised, the gateway issues **virtual, scoped keys** with limited permissions, defined expiry times, and endpoint restrictions.

1

Issue Scoped Keys

Each user or application receives a key with only the permissions it needs — specific endpoints, modalities, and quota limits.

2

Rotate Regularly

Keys are rotated on a schedule to limit exposure windows. Short-lived credentials reduce the blast radius of any single compromise.

3

Revoke Instantly

If misuse or anomalous behavior is detected, keys are revoked immediately without impacting other users or requiring system-wide changes.

Audit Trails and Access Logging

In a centralized AI gateway, every request and response is logged with rich, structured traces. These records are the foundation of security visibility enabling real-time monitoring, forensic investigation, and compliance reporting.

What Is Logged

- Virtual key used and associated identity
- Endpoint accessed and modality invoked
- Timestamp, request size, and response metadata

How Logs Are Used

- Monitor usage patterns and detect quota anomalies
- Trigger alerts on unusual access behavior
- Support incident investigation with full interaction history

Why Centralization Matters

A centralized gateway consolidates all logging in one place eliminating blind spots that occur when individual applications manage their own logging inconsistently. Security teams gain a single, authoritative source of truth for all AI interactions across the organization.
This is especially critical in multi-tenant or multi-application environments where correlating activity across services is otherwise extremely difficult.

Key Takeaways

Usage and quota limitations are foundational gateway controls that protect AI systems from abuse, resource exhaustion, and unauthorized access. Together, these controls form a layered defense strategy for production AI environments.

1 Data Size & Quantity Quotas

Prevent resource exhaustion, denial of service, and unauthorized bulk data ingestion — applied per session, day, month, and application.

2 Modality Limits

Restrict which input/output types are permitted per user, application, or region reducing attack surface and simplifying compliance enforcement.

3 Scoped Authentication

Replace master keys with rotating, scoped credentials to minimize the blast radius of any credential compromise while maintaining secure LLM access.

4 Centralized Audit Logging

Full visibility into every AI interaction enables anomaly detection, forensic investigation, and compliance reporting from a single authoritative source.